Computer Security

Definition

COMPUTER SECURITY
Properties of a computer system must hold in the presence of a resourced strategic adversary.

Key idea

If the properties hold within the threat model, it means that there are no vulnerabilities that can be exploited to materialize threats, and no harm happens.

Properties

What Properties?
TRADITIONAL PROPERTIES

- **Confidentiality** – prevention of unauthorized disclosure of information
  (e.g. The adversary should not be able to read my bank statement)
- **Integrity** – prevention of unauthorized modification of information
  (e.g. The adversary should not be able to change my bank balance)
- **Availability** – prevention of unauthorized denial of service
  (e.g. The adversary should not prevent me accessing my bank account)

NOT-SO-TRADITIONAL (BUT IMPORTANT) PROPERTIES

- Authenticity
- Anonymity
- Isolation
- Non-repudiation
- …

Security Policy

Definition

SECURITY POLICY : a high-level description of the security properties that must hold in the system in relation to assets and principals.

Definition

Assets (objects) : anything with value (e.g., data, files, memory) that needs to be protected.

Definition

Principals (subjects) : people, computer programs, services,… (may not contain the adversary)

Threat Model and Adversary

Definition

THREAT MODEL : describes the resources available to the adversary and the adversary's capabilities (observe, influence, corrupt,…)

Definition

The **adversary** is a malicious entity aiming at breaching the security policy. The adversary is strategic : the adversary will choose the optimal way to use her resources to mount an attack that violates the security properties.

Definition

THREAT MODEL
Technical term to define the adversary's capabilities.

Example

- The adversary can observe my connection
- The adversary can corrupt my machine
- The adversary controls a bank employee

Definition

VULNERABILITY
Specific weakness that could be exploited by adversaries with interest in a lot of different assets

Example

- The banking API is not protected
- The password appears in plain text in my screen

Definition

THREAT
What is the feared event, the goal of the adversary that we don't want materialized

Example

- A hacker wants to retrieve money breaking into the bank's system
- A student wants to learn my password by looking over my shoulder

Definition

HARM
The bad thing that happens when the threat materializes

Example

- The adversary steals money
- The adversary blocks access to the bank
- The adversary learns my password
- The adversary reads the message

Security Mechanism

Definition

SECURITY MECHANISM : Technical mechanism used to ensure that the security policy is not violated by an adversary within the threat model.

Example

Example 1
Policy : ensure the log of transactions is not tampered with by a single employee
Mechanism : keep a copy of the log on multiple computers, such that no single employee has access to all of them

Attacker vs Defender

Definition

ATTACKER Just one way to violate one security property is enough ! (within the threat model)

Definition

DEFENDER No adversary strategy can violate the security policy

Key idea

A system is “secure” if an adversary constrained by a specific threat model cannot violate the security policy

---

Definition

SECURITY ARGUMENT : rigorous argument that the security mechanisms in place are indeed effective in maintaining the security policy (verbal or mathematical).
Subject to the assumptions of the threat model.

Warning

FOR A THREAT MODEL TO BE USEFUL The model must constrain the adversary, otherwise we cannot make a security argument

Steps of Security Engineering

Summary

1.- High-level specification
— Define the architecture of the system (e.g., high level block diagram)
— Define the security policy (principals, assets, security properties)
— Define the threat model
2.- Security design
— Select / Design security mechanisms
— State your security argument : which controls maintain which properties ?
3.- Secure implementation
— Implement mechanisms
— Ensure they conform to the design model
— Security testing